Broker access control and where each compromise stops

he identity must hold write on the command topic, or the alarm cannot be commanded. Which identity the adversary steals is what decides the outco

PER-CLIENT ACL, as modelled

identity	cmd topic: publish	cmd topic: subscribe	stat topic: publish
controller	**allow**	deny	deny
device	deny	**allow**	**allow**

Only the controller may publish commands. The device may only read them.

Which compromise each control contains

Device credential stolen

ACL holds

the device identity has no write on the command topic, so the broker refuses the publish

Controller credential stolen

ACL fails

that identity is the one the ACL must authorise to publish commands

One shared credential stolen

ACL fails

it must carry write on the command topic, so the configuration collapses to no ACL

A MAC fails under the one compromise the ACL survives

The command key lives in the same flash image as the device's broker credentials, so a flash dump yields both.
With an ACL as well, that adversary holds a key it can sign with and a credential the broker will not let it publish commands under.